SecureVault CTF Walkthrough

22PC25 Nithin S

22PC37 Vengateshwaran k

This version includes the tools, reasoning, and decoding steps. The sections are ordered by challenge number 1 through 8.

Main tools

jadx or Android Studio

apktool

adb

sqlite3 or DB Browser for SQLite

Python for Base64 decoding

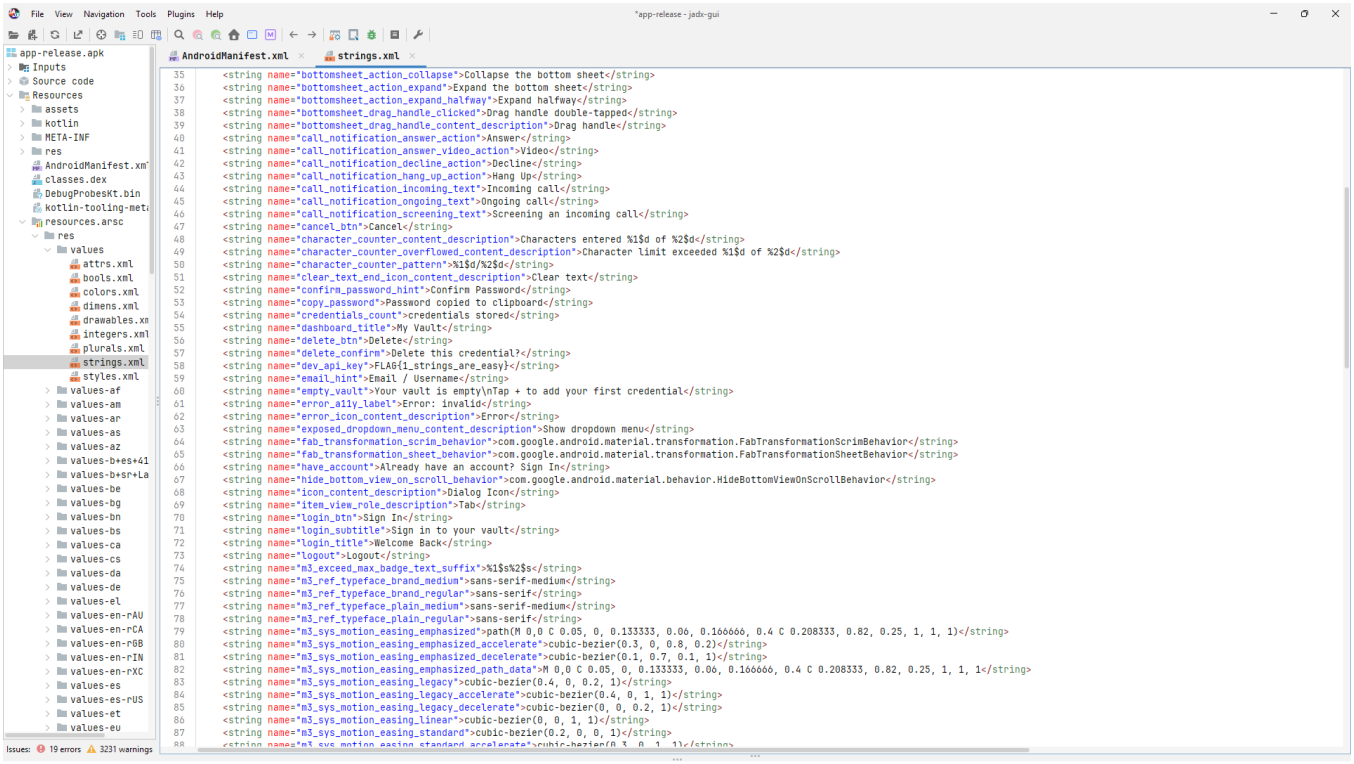
Flag 1

Where: app/src/main/res/values/strings.xml

Steps:

Open the string resources and inspect custom keys.

Find dev_api_key.



Recovered value: FLAG{1_strings_are_easy}

Flag 2

Where: app/src/main/java/com/example/securevault/database/DatabaseHelper.kt

Steps:

Inspect onCreate in the database helper.

Find the creation of the hidden table app_secrets.

Read the inserted value in sys_config_01.

```
}

@Override // android.database.sqlite.SQLiteOpenHelper
public void onCreate(SQLiteDatabase db) throws NoSuchAlgorithmException {
    Intrinsics.checkNotNullParameter(db, "db");
    db.execSQL("CREATE TABLE users (\n    id INTEGER PRIMARY KEY AUTOINCREMENT,\n    username TEXT UNIQUE NOT NULL,\n    password TEXT NOT NULL\n)");
    db.execSQL("CREATE TABLE credentials (\n    id INTEGER PRIMARY KEY AUTOINCREMENT,\n    owner_id INTEGER NOT NULL,\n    service TEXT NOT NULL,\n    email TEXT NOT NULL,\n    password_enc TEXT NOT NUL
    db.execSQL("CREATE TABLE app_secrets (key TEXT PRIMARY KEY, value TEXT)");
    db.execSQL("INSERT INTO app_secrets (key, value) VALUES ('sys_config_01', 'FLAG{2_hidden_tables_are_spooky}')");
    db.execSQL("INSERT INTO users (username, password) VALUES ('ghost_admin_007', '" + CryptoUtils.INSTANCE.hashPassword("qwertyuiop") + "')");
    db.execSQL("INSERT INTO credentials (owner_id, service, email, password_enc, notes) VALUES (1, 'Backdoor', 'ghost@vault.loc', 'RkxBR3s0X2RiX2FuYWx5c2lzX3JldmVhbHNfYWxsfQ==', 'Do not delete this acco
}

@Override // android.database.sqlite.SQLiteOpenHelper
public void onUpgrade(SQLiteDatabase db, int oldVersion, int newVersion) throws NoSuchAlgorithmException {
    Intrinsics.checkNotNullParameter(db, "db");
    db.execSQL("DROP TABLE IF EXISTS app_secrets");
```

Recovered value: FLAG{2_hidden_tables_are_spooky}

Flag 3

Where: app/src/main/java/com/example/securevault/database/DatabaseHelper.kt

Steps:

Locate the seeded backdoor account ghost_admin_007.

Notice CryptoUtils.hashPassword is called with a literal string.

Read the plaintext argument instead of trying to crack the hash.

```
 value) VALUES ('sys_config_01', 'FLAG{2_hidden_tables_are_spooky}');
password) VALUES ('ghost_admin_007', '" + CryptoUtils.INSTANCE.hashPassword("qwertyuiop") + "')");
```

Recovered value: qwertyuiop

Flag 4

Where: app/src/main/java/com/example/securevault/database/DatabaseHelper.kt

Steps:

Locate the seeded credential for the ghost admin.

Copy the password_enc value.

```
}

@Override // android.database.sqlite.SQLiteOpenHelper
public void onCreate(SQLiteDatabase db) throws NoSuchAlgorithmException {
    Intrinsics.checkNotNullParameter(db, "db");
    db.execSQL("CREATE TABLE users (\n    id INTEGER PRIMARY KEY AUTOINCREMENT,\n    username TEXT UNIQUE NOT NULL,\n    password TEXT NOT NULL\n)");
    db.execSQL("CREATE TABLE credentials (\n    id INTEGER PRIMARY KEY AUTOINCREMENT,\n    owner_id INTEGER NOT NULL,\n    service TEXT NOT NULL,\n    email TEXT NOT NULL,\n    password_enc TEXT NOT NUL
    db.execSQL("CREATE TABLE app_secrets (key TEXT PRIMARY KEY, value TEXT)");
    db.execSQL("INSERT INTO app_secrets (key, value) VALUES ('sys_config_01', 'FLAG{2_hidden_tables_are_spooky}')");
    db.execSQL("INSERT INTO users (username, password) VALUES ('ghost_admin_007', '" + CryptoUtils.INSTANCE.hashPassword("qwertyuiop") + "')");
    db.execSQL("INSERT INTO credentials (owner_id, service, email, password_enc, notes) VALUES (1, 'Backdoor', 'ghost@vault.loc', 'RkxBR3s0X2RiX2FuYWx5c2lzX3JldmVhbHNfYWxsfQ==', 'Do not delete this acco
}

@Override // android.database.sqlite.SQLiteOpenHelper
public void onUpgrade(SQLiteDatabase db, int oldVersion, int newVersion) throws NoSuchAlgorithmException {
    Intrinsics.checkNotNullParameter(db, "db");
    db.execSQL("DROP TABLE IF EXISTS app_secrets");
```

Decode the Base64 string RkxBR3s0X2RiX2FuYWx5c2lzX3JldmVhbHNfYWxsfQ==.

```
python -c "import base64;print(base64.b64decode('RkxBR3s0X2RiX2FuYWx5c2lzX3JldmVhbHNfYWxsfQ==').decode())"
```

Recovered value: FLAG{4_db_analysis_reveals_all}

Flag 5

Where: app/src/main/java/com/example/securevault/security/CryptoUtils.kt

Steps:

Find STATIC_VULN_IV.

```
private static final int ITERATIONS = 10000;
private static final String KEY_ALGORITHM = "PBKDF2WithHmacSHA256";
private static final int KEY_LENGTH = 256;
private static final String SALT = "SecureVaultSalt2024";
private static final byte[] STATIC_VULN_IV;

private CryptoUtils() {
}

static {
    byte[] bytes = "IODJ{5_sbb_pebkx_i_g_z_o}".getBytes(Charsets.UTF_8);
    Intrinsics.checkNotNullExpressionValue(bytes, "getBytes(...)");
    STATIC_VULN_IV = bytes;
}

private final SecretKeySpec deriveKey(String masterPassword) throws NoSuchAlgorithmException {
    SecretKeyFactory secretKeyFactory = SecretKeyFactory.getInstance(KEY_ALGORITHM);
```

Read the value IODJ{5_sbb_pebkx_i_g_z_o}.

Apply a Caesar shift of minus 3.

Example: I -> F, O -> L, D -> A, J -> G.

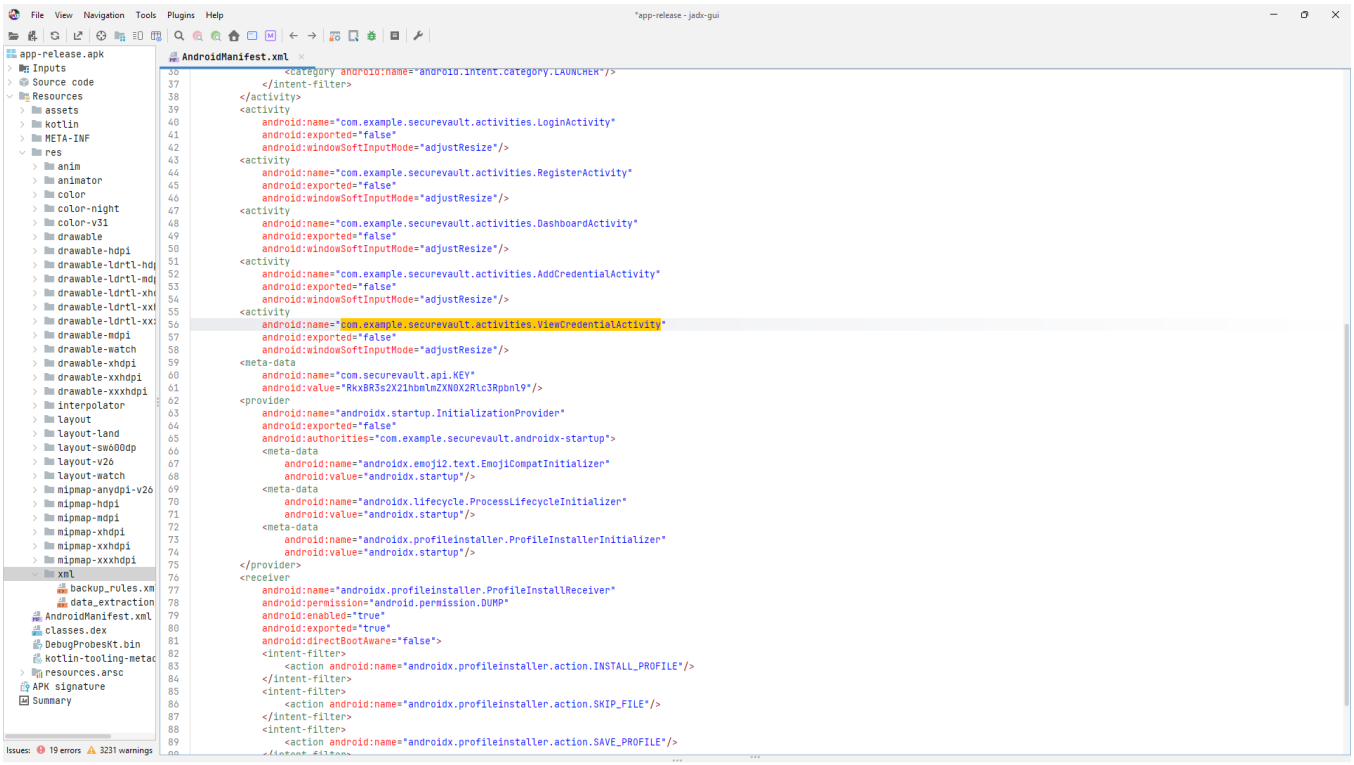
Recovered value: FLAG{5_too_many_i_v_w_l}

Flag 6

Where: app/src/main/AndroidManifest.xml

Steps:

Inspect the application metadata entry.



Copy the Base64 value RkxBR3s2X21hbmlmZXN0X2Rlc3Rpbnl9.

Decode it with Python or any Base64 decoder.

```
python -c "import base64;print(base64.b64decode('RkxBR3s2X21hbmlmZXN0X2Rlc3Rpbnl9').decode())"
```

Recovered value: FLAG{6_manifest_destiny}

Flag 7

Where: app/src/main/assets/config.json

Steps:

Open the packaged JSON config file.

```
{
  "api_endpoint": "https://api.securevault.local/v1",
  "timeout_ms": 5000,
  "retry_count": 3,
  "debug_mode": false,
  "_comment": "DO NOT DEPLOY THIS CONFIG TO PROD",
  "test_admin_token": "FLAG{7_assets_are_packaged_in_apk}"
}
```

Read test_admin_token.

Recovered value: FLAG{7_assets_are_packaged_in_apk}

Flag 8

Where: app/src/main/java/com/example/securevault/activities/AddCredentialActivity.kt

Steps:

Inspect the Generate Password click listener.

Find the condition checking notesEt.text.toString().trim() == 'givemeflag'.

Enter givemeflag in the Notes field and press Generate.

```
public static final void onCreate$lambda$2(EditText editText, EditText editText2, AddCredentialActivity addCredentialActivity, ImageBut
    if (Intrinsics.areEqual(StringsKt.trim((CharSequence) editText.getText().toString()).toString(), "givemeflag")) {
        editText2.setText("FLAG{8_dynamic_analysis_frida_hook}");
        editText2.setInputType(144);
        addCredentialActivity.isPasswordVisible = true;
        imageButton.setImageResource(android.R.drawable.ic_menu_close_clear_cancel);
```

Recovered value: FLAG{8_dynamic_analysis_frida_hook}